GETAMAZEDNOW AI

PRACTICAL AI. POSSIBLE FUTURES.

A GETAMAZEDNOW COMPANY

WHITE PAPER

Sovereignty by Design

ADSRA — an Australian Digital Sovereignty Reference Architecture for the cloud and AI era

Duane Gomes— Enterprise Architect

October 2026 · Draft v0.3 — for peer review

Companion artefacts: ADSRA Executive Briefing (deck) and ADSRA Technical Reference (engineering document)



Abstract

Australian enterprises are being asked two questions at once: exploit global cloud and AI platforms faster, and prove — to APRA, the OAIC, the Cyber and Infrastructure Security Centre, and their own boards — that they still control what matters. Most frameworks treat the second question as a compliance exercise. This paper argues it is an architecture problem, and proposes ADSRA: the Australian Digital Sovereignty Reference Architecture. ADSRA defines digital sovereignty as a first-class enterprise architecture domain, expressed through seven control pillars, twenty fundable capabilities, a six-level maturity model culminating in autonomous (agentic) sovereignty assurance, and a small set of telemetry-derived key risk indicators a Risk Committee can govern. It is published as a draft (v0.3), with its evidence base exposed, explicitly to invite peer review.

1. The sovereignty moment

For a decade, 'data residency' was a checkbox on a cloud procurement form. Three forces have converted it into a board-level architecture concern.

Regulation converged. APRA's CPS 230 came into force on 1 July 2025, making critical operations, tolerance levels and material service providers a board accountability — with pre-existing provider contracts due to comply by the earlier of renewal or 1 July 2026 (a date now passed), and notification of a tolerance-breaching disruption due within 24 hours. The Privacy and Other Legislation Amendment Act 2024 delivered a statutory tort for serious invasions of privacy (live since mid-2025) on top of the 2022 penalty uplift (the greater of $50 million or three times the benefit obtained — or, where the benefit cannot be determined, 30 per cent of adjusted turnover), and from 10 December 2026 — under ten weeks from the date of this draft — requires privacy policies to disclose substantially automated decisions that significantly affect individuals; the OAIC published its final guidance in September 2026. The SOCI Act extends risk-management and incident-reporting obligations across eleven critical-infrastructure sectors — including financial services, healthcare, energy and data storage — and the enhanced risk-management program rules commenced on 10 June 2026 for specified asset classes, with a further tranche of reforms proposed.

AI changed the data flows. Prompts, embeddings, retrieval corpora, fine-tuning sets and model telemetry now move through supply chains most enterprises cannot map. Australia's AI policy has moved twice in a year. In 2025 the Guidance for AI Adoption superseded the Voluntary AI Safety Standard, and the National AI Plan (December 2025) chose existing technology-neutral law, sector regulators and an AI Safety Institute over a standalone AI Act. On 15 July 2026 the Prime Minister announced mandatory Australian Standards for AI, a new Office of AI and legislation expected in early 2027. As announced, those standards are defined for large AI data centres (location, energy and water) and for the use of Australian creative work in AI training; the speech did not describe obligations on how an enterprise uses AI, and scope, thresholds and enforcement are unsettled. The practical consequence for enterprises is unchanged in the short term but not in direction: today the obligation is

to evidence control under existing law, and a legislated national AI framework is now coming. The evidence an enterprise can produce today is what will carry over. [Position]

Supervisors started asking. On 30 April 2026 APRA issued its first AI-specific expectations of boards and accountable executives at banks, insurers and superannuation trustees, finding that governance, risk management, assurance and operational resilience were not keeping pace with adoption. The expectations — an inventory of AI tools and use cases, human involvement in high-risk decisions, controls for AI-specific threats such as prompt injection and autonomous agents, a map of the full AI supply chain including fourth parties, contractual transparency and audit rights, credible exit and substitution strategies, and continuous monitoring proportionate to criticality — are the control set ADSRA's pillars already specify. That validates the architecture's direction; it does not make ADSRA a regulatory requirement, and the letter neither uses the word sovereignty nor cites CPS 230 or CPS 234. [Position]

Jurisdiction became a design variable. The US CLOUD Act (2018) can compel providers subject to US jurisdiction to produce data in their possession, custody or control, regardless of where it is stored. Storing data in Sydney under keys and administrators the provider controls is residency; it is not sovereignty. The Australia–US CLOUD Act Agreement (in force since January 2024) streamlines cross-border requests for serious-crime data in both directions; it does not change the analysis that jurisdiction follows the controlling entity. [Position]

> ***Residency answers 'where is the data?'. Sovereignty answers 'who can be compelled, and what can they actually produce?'***

2. Why existing frameworks don't answer the question

TOGAF supplies architecture method; SABSA derives security architecture from business attributes; the hyperscalers' well-architected frameworks optimise individual workloads; the ASD Information Security Manual and Essential Eight supply a controls baseline; and the Commonwealth's Hosting Certification Framework demonstrates — for government — what a sovereignty-graded supplier regime looks like (the framework is currently being refreshed). Each is necessary. None treats jurisdictional control of data, identity, keys, operations and AI as an enterprise architecture domain with its own capabilities, reference patterns, maturity model and measures. That is the gap ADSRA fills, and it is a gap the author believes will close within this decade the way 'zero trust' closed the network-trust gap: first as thought leadership, then as procurement language, finally as regulatory expectation.

3. ADSRA: the organising idea

ADSRA deliberately does not start with technology. It starts with control domains, and places a digital sovereignty layer between the enterprise's obligations and its platforms. Everything below the line — enterprise platforms, clouds, infrastructure — inherits the controls of that layer. Sovereignty sits above technology, not below it.

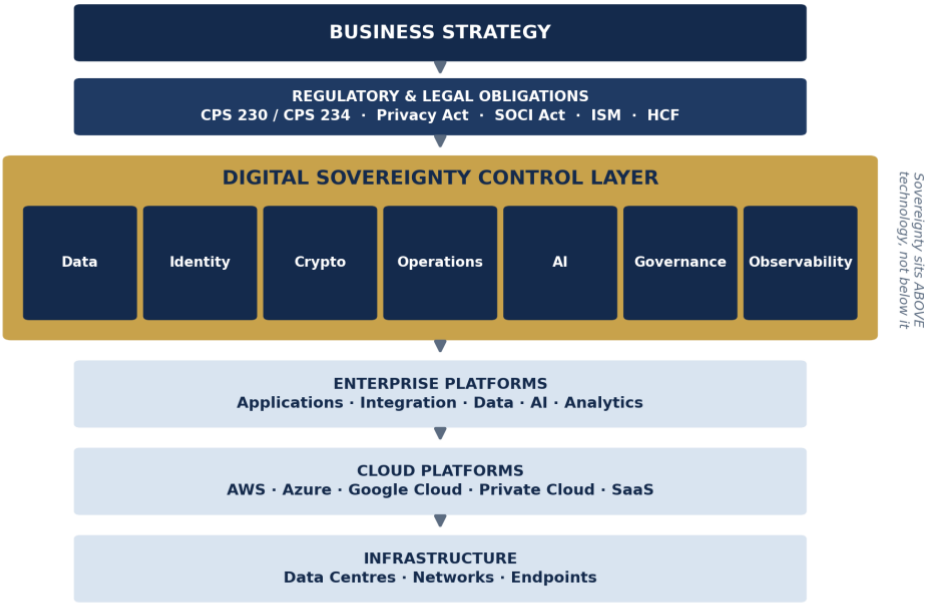


Figure 1 — ADSRA layered model: sovereignty as a first-class architecture layer

Figure 1 — The ADSRA layered model.

Inheritance is the operative word. In a mature ADSRA estate, a new workload does not negotiate its sovereignty posture; it declares its data classification, and the landing zone, policy-as-code and shared services bind the corresponding controls automatically. Exceptions are explicit, time-boxed and owned by an accountable executive.

4. The seven pillars

ADSRA decomposes sovereignty into seven pillars, each framed by the question an executive must be able to answer.



Figure — The seven ADSRA sovereignty pillars, each framed by the question an executive must be able to answer

Figure 2 — The seven ADSRA pillars.

- Data — who can legally compel access to our information? Classification with sovereignty tiers, residency, tokenisation, DLP, lifecycle and privacy assessment.
- Identity — who is acting, from where, with what privilege? Australian-controlled identity, Zero Trust conditional access, just-in-time privilege.
- Cryptographic — who controls the keys that control trust? Customer-managed keys, HSMs, BYOK/HYOK, client-side encryption, crypto-agility. Encryption is the last defence against jurisdictional uncertainty — if, and only if, the enterprise holds the keys.
- Operational — who administers production, and from which jurisdiction? Australian operations and SOC, provider-access approval, session recording, tested exit plans.
- AI — where do prompts, embeddings, inference and training occur, and who governs the outputs? Gateways, a model registry that doubles as the AI inventory, RAG governance, output validation — and decision assurance for AI-influenced decisions: algorithmic/impact assessment, explainability, contestability and human oversight, aligned to Australia's AI Ethics Principles and the National framework for the assurance of AI in government — and, for Commonwealth agencies, the DTA's Policy for the responsible use of AI in government (v2.0), which requires impact assessments for in-scope use cases by 15 December 2026.
- Governance — is compliance enforced by the platform or a policy PDF? Policy-as-code, pipeline gates, automatic inheritance — aligned to AS ISO/IEC 42001 (AI management system).
- Observability — can we prove, audit and measure sovereignty daily? Central logging, SIEM/UEBA, AI observability, immutable audit, telemetry-derived KRIs.

Observability is deliberately listed last and weighted first: it is the currently underdeveloped pillar, and the one that converts sovereignty from an asserted property into a measured one. A control without evidence should be treated as absent.

5. AI sovereignty: the model is only one component

The most consequential design error in enterprise AI today is architectural: connecting applications directly to models. ADSRA's reference flow surrounds the model with enterprise services — a prompt gateway, a policy engine, PII detection, governed retrieval, a model registry pinning approved models and regions, and response validation — with every hop recorded in an immutable audit trail.

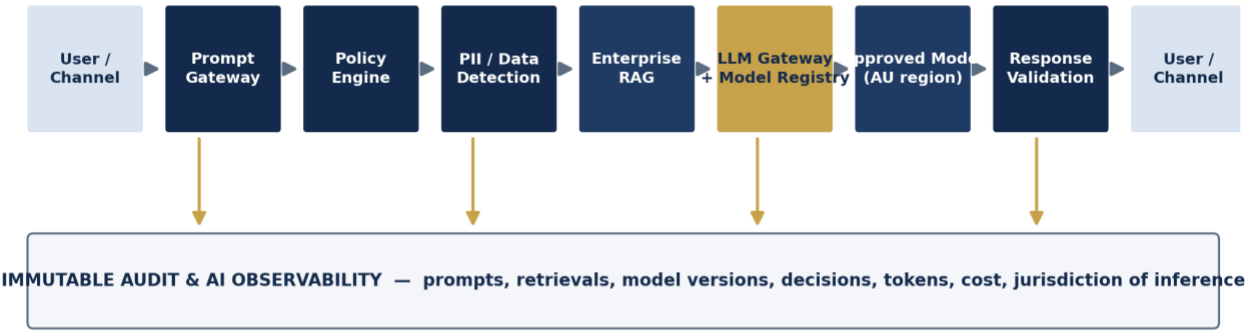


Figure — AI sovereignty reference flow: the model is only one component; every hop is policy-controlled and evidenced

Figure 3 — The AI sovereignty reference flow.

Two vignettes make it concrete. A retailer's AI pricing assistant lets merchandising teams query elasticity and promotion effects: the gateway authenticates, policy confirms the registered use case, PII detection redacts stray customer identifiers, retrieval draws only from the governed pricing corpus, and inference runs on a registry-pinned model in an Australian region. A bank's customer-service copilot goes further: customer context is tokenised before retrieval, and outputs that could constitute significant automated decisions are flagged into an ADM disclosure register that feeds the privacy-policy disclosure the Privacy Act requires from 10 December 2026; because the statutory test reaches a program that does something substantially and directly related to a decision, human review in the loop does not by itself take a use case out of scope — as the OAIC's APP 1 guidance (September 2026) confirms. In both cases the model never talks directly to users or raw data — and the audit trail can reconstruct any interaction end-to-end.

> ***The enterprises that industrialise AI first will not be the ones with the best models. They will be the ones whose governance made the models approvable.***

A note on sovereign supply. A parallel and welcome development is the emergence of Australian-owned sovereign foundational models and onshore inference. That is a supply-side effort — building sovereign capability. ADSRA is the demand-side complement: it governs and measures how an enterprise consumes AI, whether sovereign-built or global. The two are additive; neither substitutes for the other, and vendor capability claims remain market context to be verified, not evidence. Policy is moving on the supply side too: the Government's March 2026 expectations of data centres and AI infrastructure developers name national security and data sovereignty, and the Prime Minister has said the Government wants Australia to have more of a stake in where and how AI is made. [Position]

6. Classification prices the control: industry vignettes

Sovereignty is not free. Sovereign controls add cost, can break native cloud features, and in-region AI can lag frontier model availability. ADSRA's answer is a four-tier classification (Low / Medium / High / Critical) that spends the sovereignty premium only where obligations demand it. A national retailer illustrates the spread: the product catalogue (Low) runs globally on a public CDN with no premium paid at all; loyalty behaviour and customer profiles (High) are pinned to Australian regions under customer-managed keys; payment credentials (Critical) are tokenised with HSM-backed keys, an Australian SOC, and client-side encryption. Australian-owned sovereign model and compute options are beginning to narrow that in-region gap, though provider claims should be verified before reliance. [Position]

- Banking: sovereignty tiers map one-to-one to the CPS 230 critical-operations register; the 24-hour notification clock is only meetable when detection and decision rights are local and rehearsed. APRA's April 2026 AI letter adds the AI layer: an inventory of AI use cases, a mapped AI supply chain and tested exit strategies for AI providers.
- Financial services and superannuation: provider-concentration KRIs give Risk Committees a quantified exit and substitution posture across material service providers and their fourth parties.
- Retail: the statutory tort and tiered penalties concentrate in exactly the data most retailers under-classify — loyalty and behavioural profiles; personalisation AI needs review against the automated-decision transparency obligation.
- Healthcare: My Health Record information must be held and processed in Australia; connected clinical estates default to Critical, and clinical-adjacent AI runs in-region with clinicians in the loop.

Utilities: the Security of Critical Infrastructure regime pulls OT/SCADA, market and metering data under risk-management and incident-reporting duties — raised for electricity, gas and water assets by the enhanced CIRMP Rules from 10 June 2026 (12- and 24-month implementation windows; the first 12 months reportedly cover foreign ownership, control and influence and offshore remote access); sovereignty tiers map to the critical-infrastructure register, and AI for demand forecasting or outage prediction stays advisory to human operators — never actuating control systems directly.
Education: student and assessment data — much of it about minors — sits at the top tiers; tutoring and marking copilots run under human oversight with a contestability path for automated decisions, aligned to state and national AI-assurance frameworks, including the DTA's AI policy for Commonwealth agencies. The OAIC's draft Children's Online Privacy Code (which must be registered by 10 December 2026) is one to watch where learners are minors. These regulation-heavy, public-adjacent sectors are where ADSRA's control inheritance pays back fastest.

7. Measuring sovereignty: maturity and KRIs

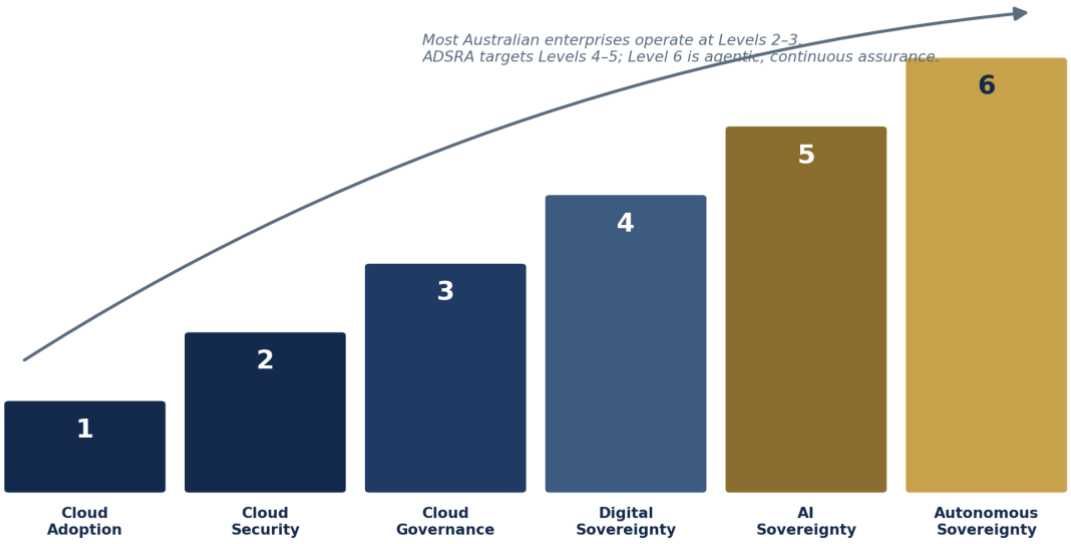


Figure 4 — The ADSRA maturity model.

Most Australian enterprises today sit at Levels 2–3 (the author's assessment [Position]): secure and increasingly governed cloud, with sovereignty handled workload-by-workload. ADSRA now targets Level 4 (sovereignty engineered into the platform) for Critical and High estates within roughly 15 months and Level 5 (AI sovereignty) within roughly 24 months — compressed from 36 because the AI-specific dates have arrived early: automated-decision transparency on 10 December 2026, APRA's AI expectations already issued, and a national AI framework expected in legislation in early 2027. [Position] The compression is judgement, not regulation: the hard dates are those in statute and the CIRMP implementation windows (10 June 2027 and 10 June 2028 for the asset classes covered). Level 6 — autonomous sovereignty — is the model's genuinely new contribution: AI agents continuously interrogating the estate. Is every workload still compliant? Has data crossed a jurisdiction? Is a key nearing expiry? Has inference moved offshore? Is an administrator operating from an unexpected location? At Level 6 the platform does not merely monitor sovereignty; it assesses and remediates it, under human oversight. Within the 24-month window Level 6 is a pilot ambition, not a production one [Position]; APRA's expectation that second-line functions can assess autonomous workflows is a reminder that agentic assurance must itself be governed.

Between board meetings, a handful of telemetry-derived indicators carry the story: the percentage of High/Critical data under customer-managed keys; the percentage of privileged sessions administered from Australia (and recorded); the percentage of AI inference executed in-region through the gateway; first-time pass rates through policy-as-code gates; mean time to detect a cross-jurisdiction data movement; the recency of tested exit plans for material providers; and the percentage of AI tools and use cases held in a single inventory, as APRA now expects of the entities it regulates. None of these is an attestation. All of them are computable from the observability pillar — which is precisely why that pillar is the first investment.

8. The business case, stated honestly

The return side of the ledger: penalty and tort exposure avoided; faster risk approval of cloud and AI initiatives because patterns are pre-agreed; quantified provider-concentration risk instead of implicit acceptance; and — increasingly decisive — the licence to deploy customer-facing AI at all, because evidenced control is what boards and regulators now ask for first. APRA's April 2026 AI letter makes the same point from the supervisor's side.

The cost side deserves equal candour: HYOK and client-side encryption break real cloud features and should be applied surgically; in-region model availability lags the frontier; over-classification taxes low-risk workloads; and policy-as-code and AI-governance engineering skills are scarce. The managed position is not maximal sovereignty — it is tiered sovereignty, consciously priced, with residual risk measured and accepted in the open. The in-region frontier-availability gap is narrowing as Australian sovereign model and compute options mature. [Position]

9. A call to the profession

ADSRA is published deliberately as a v0.3 draft, with its evidence register exposed in the companion Technical Reference. The tier boundaries, the HYOK guidance, the Level 6 definition, and the technology mappings all carry open questions that practitioner review will improve. Just as the industry evolved from 'security' to zero trust as a first-class architectural principle, the author expects it to evolve from 'data residency' to digital sovereignty architecture as a formal enterprise architecture domain — and would rather Australian practitioners define that evolution than inherit it. Comments, challenges and contributed industry blueprints (the utilities and education blueprints are now drafted — corrections and co-authors are explicitly invited) are welcome.

References

- APRA, Prudential Standard CPS 230 Operational Risk Management (in force 1 July 2025; targeted amendments final 30 April 2026, effective 1 July 2026) and CPG 230 — apra.gov.au.
- APRA, Prudential Standard CPS 234 Information Security (2019).
- APRA, Letter to industry on artificial intelligence (AI), 30 April 2026 — apra.gov.au.
- Privacy Act 1988 (Cth); Privacy and Other Legislation Amendment Act 2024 (Cth); Privacy Legislation Amendment (Enforcement and Other Measures) Act 2022 (Cth); OAIC, APP 1.7–1.9 transparency resources and APP Guidelines Chapter 1 (September 2026); Privacy (Children's Online Privacy) Code 2026 (exposure draft; must be registered by 10 December 2026) — oaic.gov.au.
- Security of Critical Infrastructure Act 2018 (Cth) and CIRMP Rules, including the Enhanced CIRMP Rules 2026 (commenced 10 June 2026); Department of Home Affairs, SOCI Act Tranche 2 consultation paper (submissions closed 31 July 2026; proposals only) — cisc.gov.au.
- ASD/ACSC, Information Security Manual and Essential Eight; IRAP — cyber.gov.au.
- DTA / Home Affairs, Hosting Certification Framework (refresh under way) — hostingcertification.gov.au.

- My Health Records Act 2012 (Cth).
- Clarifying Lawful Overseas Use of Data (CLOUD) Act 2018 (US).
- Agreement between the United States and Australia on Access to Electronic Data for the Purpose of Countering Serious Crime (in force January 2024).
- DISR / National AI Centre: Voluntary AI Safety Standard (2024); Guidance for AI Adoption (Oct 2025); National AI Plan (Dec 2025); Australian AI Safety Institute (operational 2026; advisory, not a regulator); Expectations of data centres and AI infrastructure developers (23 March 2026) — industry.gov.au.
- Prime Minister of Australia, 'AI in Australia's interests' (speech, 15 July 2026) — pm.gov.au.
- DTA, Policy for the responsible use of AI in government v2.0 (effective 15 December 2025; impact-assessment requirement for in-scope use cases by 15 December 2026) — digital.gov.au.
- Parliament of Australia, Joint Select Committee on Artificial Intelligence (appointed 20 August 2026; final report reported as due 30 November 2026) — aph.gov.au.
- ISO/IEC 42001:2023; NIST AI RMF 1.0.

Australian, state and territory governments, National framework for the assurance of artificial intelligence in government (v1.0, 21 June 2024), based on Australia's AI Ethics Principles (DISR 2019); AS ISO/IEC 23894:2023; AS ISO/IEC 38507:2022.

All regulatory dates as at 2 October 2026. Items described as proposed, announced or draft are not obligations. The companion ADSRA Technical Reference contains the full evidence register mapping every claim to its source.